

Sicurezza

CdL in Informatica – L31

Lezione 2 – Capitolo 2

Prof. Emiliano Casalicchio

Department of Computer Science

Sapienza University of Rome



SAPIENZA
UNIVERSITÀ DI ROMA



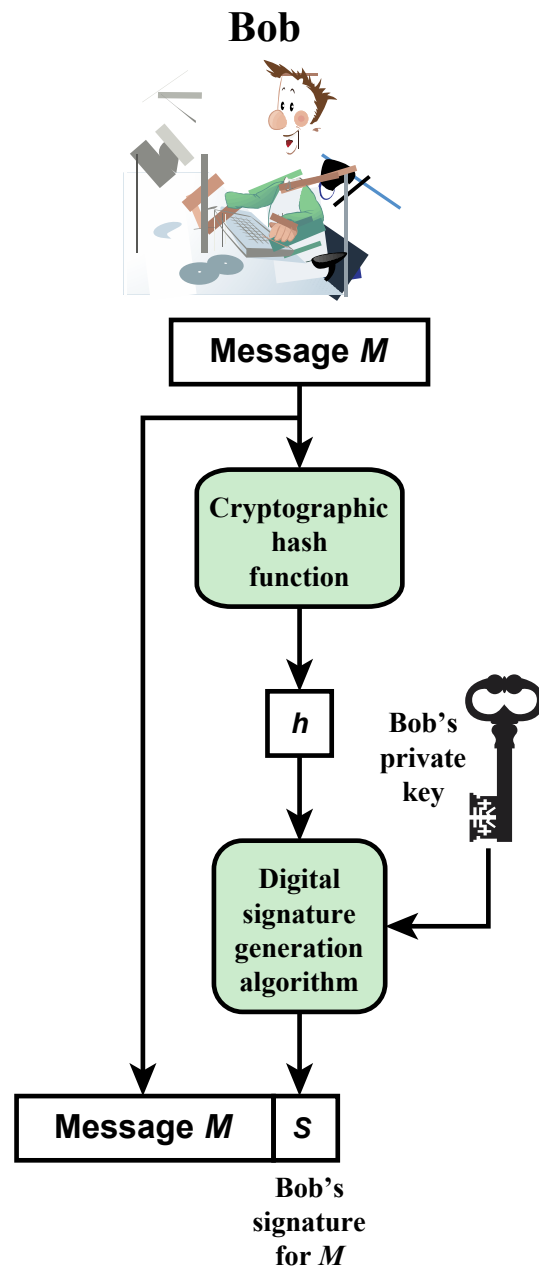
Topics

- ~~Confidentiality with symmetric encryption~~
- ~~Message authentication and hash functions~~
- ~~Public key encryption~~
- Digital signature and key management
- Random and pseudorandom numbers

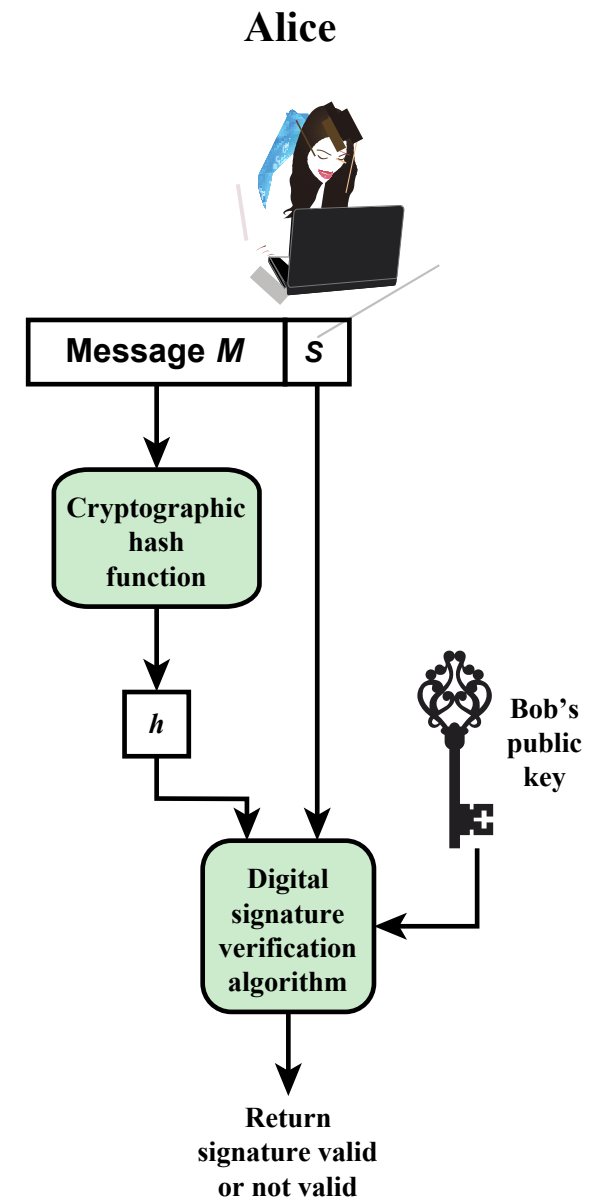
Digital Signatures

- NIST FIPS PUB 186-4 defines a digital signature as:
"The result of a cryptographic transformation of data that, when properly implemented, provides a mechanism for verifying origin authentication, data integrity and signatory non-repudiation."
- Thus, a digital signature is a data-dependent bit pattern, generated by an agent as a function of a file, message, or other form of data block
- FIPS 186-4 specifies the use of one of three digital signature algorithms:
 - Digital Signature Algorithm (DSA)
 - RSA Digital Signature Algorithm
 - Elliptic Curve Digital Signature Algorithm (ECDSA)

- Essential elements of digital signature
- It provides authentication of the source of the message and data integrity
- It does not provide confidentiality



(a) Bob signs a message



(b) Alice verifies the signature

- Quale e' la vulnerabilita' di questo schema?

The vulnerability of the public key digital signature schema proposed

- The point of public-key encryption is that the public key is public!!!
- Advantage
 - any participant can send his or her public key to any other participant or broadcast the key to the community at large.
- Drawback
 - Anyone can forge such a public announcement. That is, some user could pretend to be Bob and send a public key to another participant or broadcast such a public key
 - the forger is able to read all encrypted messages intended for Bob and can use the forged keys for authentication.

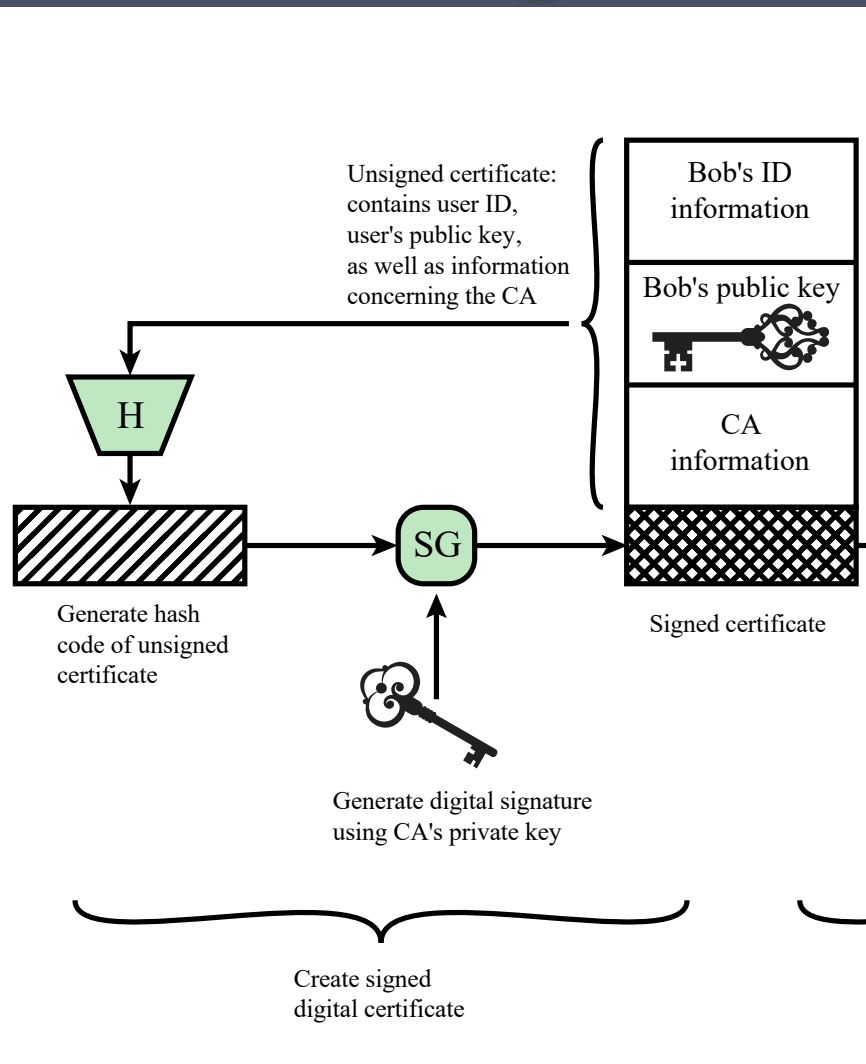
The solution: Public Key Certificate

- A certificate consists of
 - a public key +
 - a user ID of the key owner
 - Info about the third party, a Certification Authority (CA), that guarantees for the certificate. CA is trusted by the user community (gov agency, financial institution, ...)
 - Period of validity
- The whole block is signed by the third party (CA).
- A user can present his or her public key to the CA in a secure manner and obtain a signed certificate
- The user can then publish the certificate. Anyone needing this user's public key can obtain the certificate and verify that it is valid by means of the attached trusted signature

Aruba PEC S.p.A.
InfoCert S.p.A.
Poste Italiane S.p.A.
Register.it S.p.A.

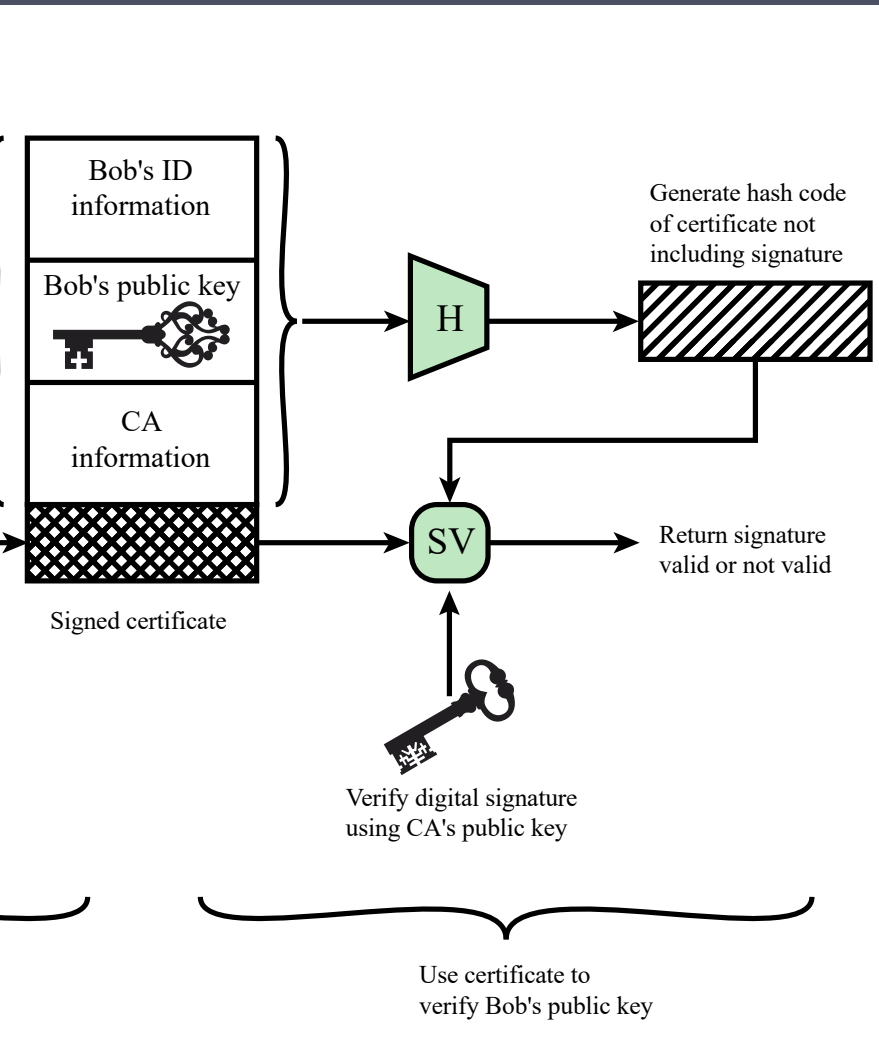
...

■ Signed Certificate creation



1. User software (client) creates a pair of keys: one public and one private.
2. Client prepares an unsigned certificate that includes the user ID and user's public key.
3. User provides the unsigned certificate to a CA in some secure manner.
4. CA creates a signature as follows:
 - a. CA uses a hash function to calculate the hash code of the unsigned certificate.
 - b. CA generates digital signature using the CA's private key and a signature generation algorithm.
5. CA attaches the signature to the unsigned certificate to create a signed certificate.
6. CA returns the signed certificate to client.

Signed Certificate use to verify Public-key



7. Client may provide the signed certificate to any other user

8. Any user may verify that the certificate is valid as follows:

a. User calculates the hash code of certificate (not including signature).

b. User verifies digital signature using CA's public key and the signature verification algorithm. The algorithm returns a result of either signature valid or invalid

At this point the Bob's public key is verified as authentic and can be used by the user

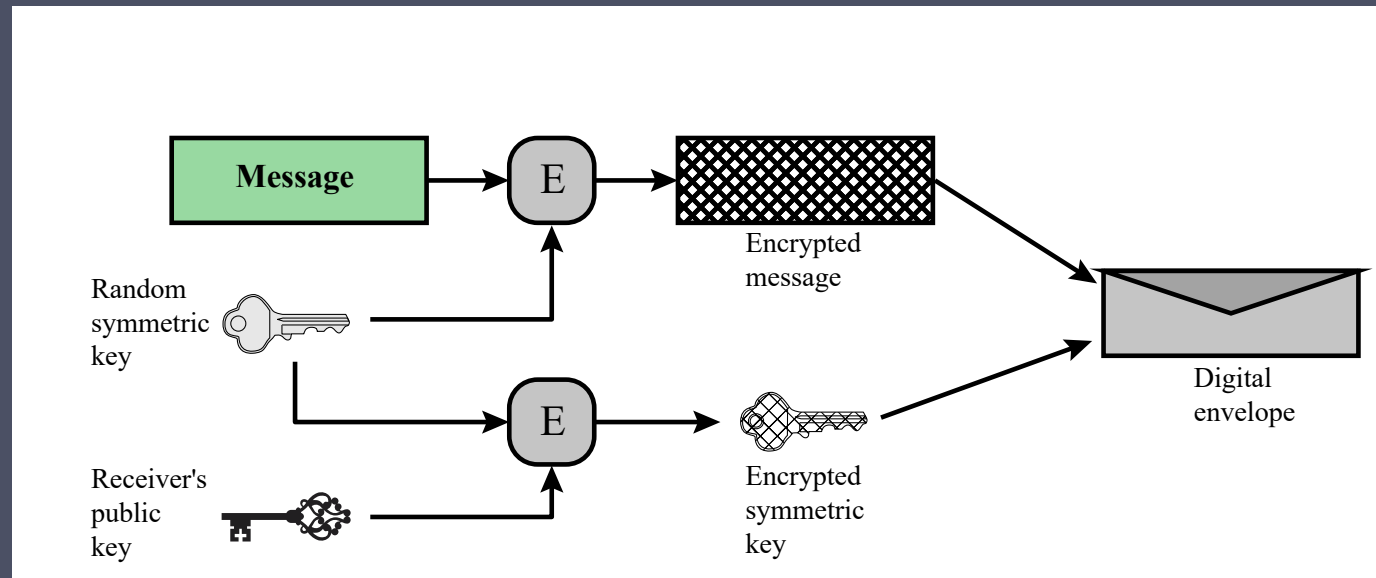
X.509 is the standard schema for formatting public-key certificates

Digital Envelope

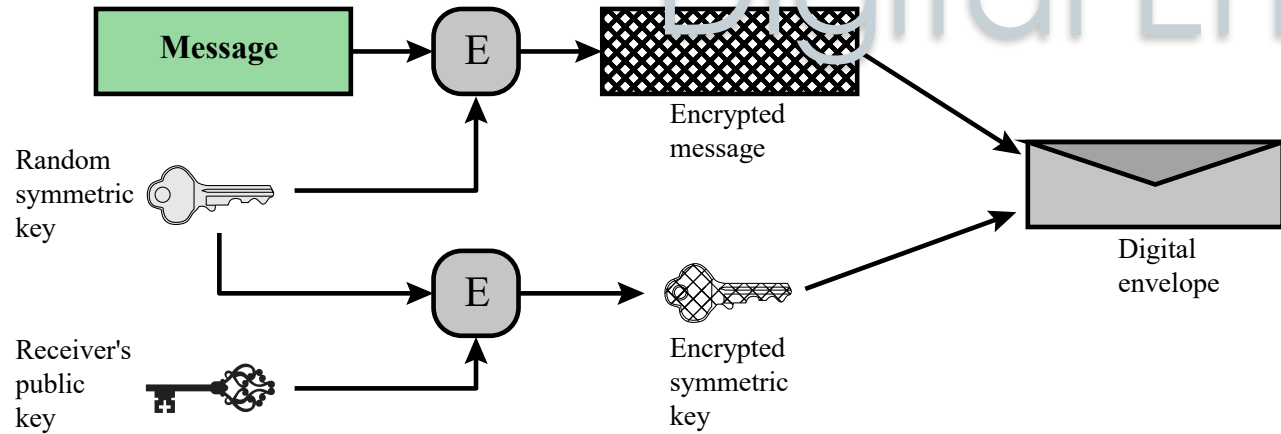
- Public-key encryption is used to protect a symmetric key
- Bob wishes to send a confidential message to Alice, but they do not share a symmetric secret key

Bob:

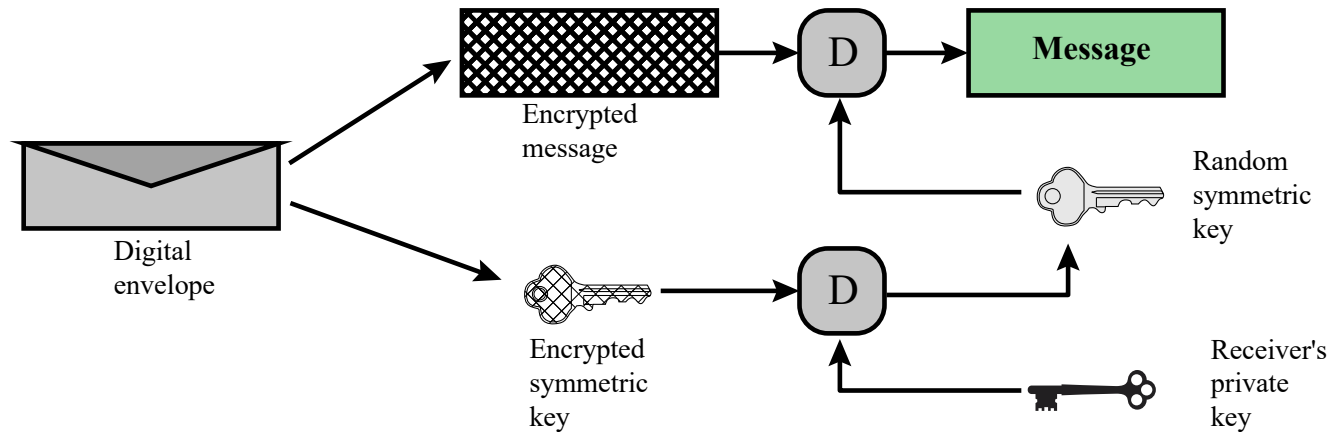
1. Prepare a message.
2. Generate a random symmetric key that will be used this one time only.
3. Encrypt that message using symmetric encryption the one-time key.
4. Encrypt the one-time key using public-key encryption with Alice's public key.
5. Attach the encrypted one-time key to the encrypted message and send it to Alice.



Digital Envelope



(a) Creation of a digital envelope



(b) Opening a digital envelope

Figure 2.9 Digital Envelopes

- Only Alice is capable of decrypting the one-time key and therefore of recovering the original message
- If Bob obtained Alice's public key by means of Alice's public-key certificate, then Bob is assured that it is a valid key

Random Numbers

Uses include generation of:

- Keys for public-key algorithms
- Stream key for symmetric stream cipher
- Symmetric key for use as a temporary session key or in creating a digital envelope
- Handshaking to prevent replay attacks
- Session key

Random Number Requirements

Randomness

- Criteria:
 - Uniform distribution
 - Frequency of occurrence of each of the numbers should be approximately the same
 - Independence
 - No one value in the sequence can be inferred from the others
 - Hard to prove

Unpredictability

- Each number is statistically independent of other numbers in the sequence
- Opponent should not be able to predict future elements of the sequence on the basis of earlier elements

Random versus Pseudorandom

Cryptographic applications typically make use of algorithmic techniques for random number generation

- Algorithms are deterministic and therefore produce sequences of numbers that are not statistically random



Pseudorandom numbers are:

- Sequences produced that satisfy statistical randomness tests
- Likely to be predictable



True random number generator (TRNG):

- Uses a nondeterministic source to produce randomness. Measures unpredictable natural or physical processes
 - e.g. Hardware RNG: thermal and shot noise, jitter and metastability of electronic circuits, quantum effects
- Increasingly provided on modern processors

Summary

- Confidentiality with symmetric encryption
 - Symmetric encryption
 - Symmetric block encryption algorithms
 - Stream ciphers
- Message authentication and hash functions
 - Authentication using symmetric encryption
 - Message authentication without message encryption
 - Secure hash functions
 - Other applications of hash functions
- Random and pseudorandom numbers
 - The use of random numbers
 - Random versus pseudorandom
- Public-key encryption
 - Structure
 - Applications for public-key cryptosystems
 - Requirements for public-key cryptography
 - Asymmetric encryption algorithms
- Digital signatures and key management
 - Digital signature
 - Public-key certificates
 - Symmetric key exchange using public-key encryption
 - Digital envelopes